TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

WordPress Core update race condition allows unauthenticated RCE and is being hammered

From **Cybersecurity Briefing** · 2026-10-28 to 2026-11-02 (US/Global/Industry focus on the last 24 hours plus weekend; local sections cover five days) · Briefing generated 2026-11-02

REPORT ID	VERSION	HANDLING
CTI-20261102-03	1.0 · 2026-11-02 12:40 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
	2026-10-30	No update
CVES	**ANALYST**	
CVE-2026-119977 (CVSS 8.1)	Nick Sturgeon	

VULNERABILITY HIGH

ACTIVELY EXPLOITED (ATTEMPTS OBSERVED; NO CONFIRMED COMPROMISES REPORTED)

OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

WordPress Core 4.7 through 7.1.3 has a race condition in its update process. During a full-package core update, WordPress unpacks a complete copy of itself, including the installer, into a folder under the web-served wp-content/upgrade directory. An unauthenticated attacker who requests the staged installer before cleanup can reach PHP code execution [S2] [S5] [S6]. The flaw was fixed in WordPress 7.1.4 on 2026-10-28, with backports to every branch back to 4.7 [S2] [S4]. The briefing item says no CVE exists, but that has changed: Wordfence, acting as CNA, published CVE-2026-119977 on 2026-10-31 with CVSS 8.1 and CWE-367 [S5].

Attackers moved quickly. The first match on Wordfence's firewall rule came nine minutes after it was deployed at 20:30 UTC on 2026-10-28, and Wordfence recorded more than 18,500 requests against staged installer paths in the first 21 hours. Its two largest sources polled small groups of sites for about 14.5 hours, which fits an attempt to catch the upgrade window [S6]. The Hacker News reports a larger figure of 62,969 blocked attacks in 24 hours, attributed to Wordfence [S1], but two later write-ups could not find that number in Wordfence's post [S9] [S10]. Both counts measure attempts blocked by one vendor. No source reports a confirmed compromise, and the flaw was not in the CISA KEV catalog in the version checked (2026.10.30) [S9] [S10] [S11].

Real-world risk is narrower than the 8.1 score and the attack counts suggest. The window lasted only seconds in Wordfence's lab tests, and the attacker must find the staging path while the directory is reachable with PHP enabled [S6]. Patchstack adds that the installer route needs a database the attacker controls, and it does not consider the flaw practical to exploit [S7]. WordPress rates the advisory Low [S2]. EPSS was 0.6% on 2026-11-02 [S12]. The consequence of a win is still code execution as the web server user, so this should be treated as an urgent patch with a targeted hunt, not as a mass-compromise emergency [S10].

The order of work matters: the update to 7.1.4 itself runs the old, vulnerable code, so the safest sequence is to deny web access to wp-content/upgrade/ at the server, CDN or WAF first, then update [S8] [S13]. Plugin firewalls that load inside WordPress may not see these requests, because the staged copy loads its own files [S7] [S10]. Any site updated on or after 2026-10-28 should have its logs reviewed around the update time, along with checks for rogue administrators, plugins and PHP files [S1] [S6] [S10]. No attacker IPs, user agents, hashes or webshell names have been published, so hunting has to rely on paths and behavior [S9] [S10].

Key judgments

> **ALMOST CERTAIN · HIGH CONFIDENCE**
> Automated probing of wp-content/upgrade and staged installer paths will continue for at least the next two weeks, because attackers are already polling and sites that have not yet updated still face the window when they do. [S1] [S6] [S10]

> **UNLIKELY · MODERATE CONFIDENCE**
> This race alone will produce mass compromise on the scale of a directly exploitable pre-authentication flaw in the next 30 days, given the seconds-long window, the path and web access preconditions, and the fact that each site's exposure ends once it is patched. [S6] [S7]

> **ROUGHLY EVEN CHANCE · LOW CONFIDENCE**
> A credible vendor or responder will publicly confirm at least one successful compromise through this flaw within 30 days. Sustained polling across many sites favors some wins, but evidence on a small site is easy to miss. [S6] [S10]

> **LIKELY · MODERATE CONFIDENCE**
> A working public proof of concept will appear within 30 days. The fix makes only a few changes and the CVE record links the relevant code, although no public proof of concept had been found as of 2026-11-02. [S5] [S8] [S10]

INDICATORS OF COMPROMISE

No IP addresses, domains, hashes, user agents or webshell names have been published by WordPress, Wordfence or Patchstack as of 2026-11-02 [S9] [S10]. Everything below is a path, request or host behavior from

reporting dated 2026-10-28 to 2026-11-02, or a clearly marked inference from it; a single log hit is a lead, not proof of compromise [S8].

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`wp-content/upgrade/`	Web-served staging directory targeted by the attacks. Requests for PHP files here are suspicious, because legitimate visitors should never request them.	REPORTED	2026-10-28	[S1] [S6] [S10]
filename	`setup-config.php`	WordPress installer file polled repeatedly by attackers when requested from a staged path. A request for it outside the normal wp-admin location is the strongest network lead.	REPORTED	2026-10-28	[S1] [S6] [S7]
filepath	`wp-content/upgrade/<staging-folder>/wp-admin/setup-config.php`	Pattern, not a literal path. The extracted copy includes wp-admin/setup-config.php, which can run without site configuration. The sources do not publish the exact staged path; a further subfolder may sit between the staging folder and wp-admin, and attackers vary folder and version names.	DERIVED		[S6] [S7]
http-request	`POST <staged path>/setup-config.php returning HTTP 200`	Treated as a probable compromise by one hunting guide, since a POST indicates interaction with the installer and not only polling.	REPORTED		[S10]
http-request	`GET or POST of any *.php under /wp-content/upgrade/`	Base hunting pattern. Prioritize HTTP 200 responses and decode percent-encoded paths first, because attackers vary spellings.	REPORTED	2026-10-28	[S6] [S8] [S10]
http-request	`GET /wp-content/upgrade/ returning HTTP 200`	A 200 on the bare folder may expose the staging folder name where directory listing is enabled. Before the fix, cleanup deleted the index.php that prevents listing.	REPORTED		[S7] [S10]
filename	`install.php`	Installer file to look for when requested outside the normal wp-admin location, especially by POST.	REPORTED		[S10]
filepath	`wp-content/upgrade/*/wp-config.php`	An unexpected config file in the staging tree warrants investigation. Before the fix, the update copy step did not exclude wp-config.php, so a file written here could be copied to the site root.	REPORTED		[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`wp-content/upgrade/*.php (any file other than index.php)`	Between updates the folder should hold only index.php on fixed sites. Failed updates can also leave files behind, so check before treating this as malicious.	REPORTED		[S7] [S8] [S10]
filepath	`wp-content/uploads/*.php`	Persistence location to check for PHP files newer than 2026-10-27.	REPORTED		[S10]
filepath	`wp-content/mu-plugins/`	Persistence location to check for new or changed must-use plugins.	REPORTED		[S10]
filename	`.htaccess`	Check for unexpected changes near the update time.	REPORTED		[S10]
filename	`wp-config.php`	Check the site-root copy for unexpected changes near the update time. Comparing the database host against the expected value is a reasonable added check, given the attacker-controlled database requirement.	REPORTED		[S7] [S10]
http-request	`wp-admin/update-core.php?action=do-core-upgrade`	Benign timing marker for a dashboard-driven update. Use it to set the review window of 5 minutes before to 10 minutes after the update.	REPORTED		[S10]
filepath	`wp-includes/version.php`	Benign timing marker. Its modification time shows when the site was updated, which sets the log review window.	REPORTED		[S10]
other	`Web server or PHP process spawning a shell or download tool`	Host-level sign of post-exploitation. PHP's mail() spawning sendmail is a known false positive.	REPORTED		[S10]
other	`One source polling a few wp-content/upgrade paths for many hours`	Behavior of the two largest sources Wordfence saw, which polled small groups of sites for about 14.5 hours. Many path variants from one source points to scanning instead.	REPORTED	2026-10-28	[S6] [S10]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	`3306/tcp outbound from web host to an unfamiliar host during an update window`	Inferred from Patchstack's statement that the installer route needs a database the attacker controls, and from 3306 being the default MySQL port. No source reports this traffic, and an attacker could use another port.	DERIVED		[S7]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker repeatedly requests paths under wp-content/upgrade, waiting for a site to begin a full-package core update. During that update, the new release is unpacked into a staging folder whose name is predictable or discoverable, and the copy includes the installer. Because the installer's guard only checks for an existing wp-config.php and release packages ship only a sample, the staged setup-config.php will run [S8]. Patchstack says the installer route needs an attacker-controlled database [S7], and the pre-fix copy step could carry a wp-config.php from the staging tree to the site root [S8]. If the attacker finishes before cleanup, the result is PHP code execution as the web server user [S6] [S10]. Sources describe scanning and polling only. Post-exploitation steps below come from defender checklists and have not been observed in reported attacks.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.003 Active Scanning: Wordlist Scanning	Sources test many staging-directory and version-name variations under wp-content/upgrade to find a live path. [S1] [S6]	One client requesting many distinct paths under wp-content/upgrade, mostly returning 404.
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Sources poll staged setup-config.php paths on small groups of sites for about 14.5 hours to catch the upgrade window. [S1] [S6] [S10]	One client making sustained requests to a few paths under wp-content/upgrade over many hours.
Initial Access	T1190 Exploit Public-Facing Application	An unauthenticated request reaches the staged installer during a full-package core update and progresses to PHP code execution. [S2] [S5] [S6]	HTTP 200 for PHP under wp-content/upgrade, especially a POST to a staged setup-config.php, close to a site's update time.

Tactic	Technique	Procedure observed	Detection opportunity
Persistence	T1505.003 Server Software Component: Web Shell	Not observed in reporting. Defenders are told to look for unfamiliar PHP files in upgrade, uploads and mu-plugins after a possible win. [S1] [S6] [S10]	New PHP files in those folders outside the normal update burst; core checksum verification.
Persistence	T1136.001 Create Account: Local Account	Not observed in reporting. Defenders are told to look for unfamiliar WordPress administrator accounts. [S1] [S6] [S10]	Review administrator accounts and creation dates against the update time.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Not observed in reporting. Web server or PHP processes spawning shells or download tools is listed as a compromise check. [S10]	EDR process lineage from PHP or web server parents to shells, curl or wget, excluding sendmail from mail().

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

PHP requests under wp-content/upgrade `SPLUNK SPL`

```
index=web sourcetype=access_combined uri_path="*/wp-content/upgrade/*" uri_path="*.php"
| stats count dc(uri_path) AS distinct_paths values(status) AS statuses values(method) AS methods
earliest(_time) AS first latest(_time) AS last BY clientip host
| eval hours=round((last-first)/3600,1)
| sort - count
```

Adjust index and field names. Long duration with few distinct paths suggests polling; many distinct paths suggests scanning. Prioritize status 200 and POST. Search from 2026-10-28 and add each site's update time.

Web request to PHP in the WordPress upgrade folder `SIGMA`

```
title: Web Request to PHP Under WordPress Upgrade Folder
status: experimental
logsource:
  category: webserver
detection:
  selection_path:
    cs-uri-stem|contains: '/wp-content/upgrade/'
  selection_php:
    cs-uri-stem|contains: '.php'
  condition: selection_path and selection_php
falsepositives:
  - Security scanners run by the site owner
level: high
```

Raise to critical when the method is POST, the file is setup-config.php and the status is 200. Decode percent-encoding before matching where the pipeline allows.

Web server process spawning shell or download tool `KQL`

```
DeviceProcessEvents
| where Timestamp > datetime(2026-10-28)
| where InitiatingProcessFileName in~ ("php", "php-fpm", "php-cgi", "apache2", "httpd", "nginx",
"lsphp", "w3wp.exe", "php-cgi.exe")
| where FileName in~ ("sh", "bash", "dash", "curl", "wget", "nc", "python", "python3", "perl",
"cmd.exe", "powershell.exe")
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName
```

For Microsoft Defender for Endpoint. Requires an agent on the web host, which shared hosting usually does not allow. Expect some noise: PHP's mail() can invoke sendmail through a shell, a known false positive.

Inbound HTTP request for PHP in the upgrade folder `SURICATA`

```
alert http any any -> $HOME_NET any (msg:"Possible WordPress upgrade-window probe (CVE-2026-119977)";
flow:established,to_server; http.uri; content:"/wp-content/upgrade/"; nocase; pcre:"/\/wp-
content\/upgrade\/[^?]*\.php(?:\?|$)/i"; classtype:web-application-attack; sid:1000001; rev:1;)
```

Sees only unencrypted traffic or traffic behind TLS termination. Replace the sid with one from a local range. Expect many alerts from opportunistic probing, most of which will not indicate compromise.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
WordPress Core 7.1	7.1.0 to 7.1.3	7.1.4	CVE-2026-119977	8.1 (Wordfence CNA); WordPress rates Low	0.6%, 48.7th percentile (2026-11-02)	No	N/A
WordPress Core 7.0	7.0.0 to 7.0.7	7.0.8	CVE-2026-119977	8.1 (Wordfence CNA); WordPress rates Low	0.6%, 48.7th percentile (2026-11-02)	No	N/A
WordPress Core 6.6 to 6.9	6.9.0 to 6.9.10; 6.8.0 to 6.8.11; 6.7.0 to 6.7.10; 6.6.0 to 6.6.10	6.9.11; 6.8.12; 6.7.11; 6.6.11	CVE-2026-119977	8.1 (Wordfence CNA); WordPress rates Low	0.6%, 48.7th percentile (2026-11-02)	No	N/A
WordPress Core 6.0 to 6.5	6.5.0 to 6.5.13; 6.4.0 to 6.4.13; 6.3.0 to 6.3.13; 6.2.0 to 6.2.14; 6.1.0 to 6.1.15; 6.0.0 to 6.0.17	6.5.14; 6.4.14; 6.3.14; 6.2.15; 6.1.16; 6.0.18	CVE-2026-119977	8.1 (Wordfence CNA); WordPress rates Low	0.6%, 48.7th percentile (2026-11-02)	No	N/A
WordPress Core 5.0 to 5.9	5.9.0 to 5.9.19; 5.8.0 to 5.8.18; 5.7.0 to 5.7.20; 5.6.0 to 5.6.22; 5.5.0 to 5.5.23; 5.4.0 to 5.4.24; 5.3.0 to 5.3.26; 5.2.0 to 5.2.29; 5.1.0 to 5.1.27; 5.0.0 to 5.0.30	5.9.20; 5.8.19; 5.7.21; 5.6.23; 5.5.24; 5.4.25; 5.3.27; 5.2.30; 5.1.28; 5.0.31	CVE-2026-119977	8.1 (Wordfence CNA); WordPress rates Low	0.6%, 48.7th percentile (2026-11-02)	No	N/A
WordPress Core 4.7 to 4.9	4.9.0 to 4.9.34; 4.8.0 to 4.8.33; 4.7.0 to 4.7.38	4.9.35; 4.8.34; 4.7.39	CVE-2026-119977	8.1 (Wordfence CNA); WordPress rates Low	0.6%, 48.7th percentile (2026-11-02)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
WordPress Core 4.6 and earlier	Outside the listed range; receives no security updates	None; upgrade to a supported release	Not listed	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Deny web access to wp-content/upgrade/ at the web server, CDN or WAF before updating, and confirm it returns 403 with no directory listing. Example for nginx: location ^~ /wp-content/upgrade/ { deny all; }. Example for Apache 2.4: a Directory block for that folder with Require all denied. `IT OPS` [S7] [S8] [S10] [S13]
- Update every site to 7.1.4 or the fixed release for its branch, then verify the version in the dashboard. Do not assume automatic updates succeeded. `IT OPS` [S2] [S6] [S16]
- Search access logs from 2026-10-28 for PHP requests under wp-content/upgrade, prioritizing 200 responses and any POST to a staged setup-config.php. Preserve logs before they rotate. `SOC` [S1] [S8] [S10]
- For each site, review requests from 5 minutes before to 10 minutes after its update time. Use the wp-includes/version.php modification time to find that time. `SOC` [S10]
- Check for unfamiliar administrators, unexpected plugins, PHP files other than index.php in wp-content/upgrade, and new PHP files in uploads or mu-plugins. `SOC` [S1] [S6] [S10]

Short term (1–7 days)

- Inventory all WordPress sites, including forgotten microsites and client-managed ones, by branch, update method, host and whether wp-content/upgrade is blocked. Record any on 4.6 or earlier. `IT OPS` [S6] [S14]
- Run core and plugin checksum verification and a malware scan on sites that updated since 2026-10-28. Check wp-config.php, .htaccess and must-use plugins for changes. `SOC` [S6] [S10]
- On Wordfence-protected sites, confirm the firewall is optimized with Extended Protection. Free users do not receive the rule until 2026-11-27, so they need the server-level block. `IT OPS` [S6] [S9]
- If compromise is found, take the site offline, preserve evidence, assess the host and its neighboring sites, rebuild from known-good sources at the fixed version, and rotate database, salt, admin, API and hosting credentials. `SOC` [S10]
- Remove leftover files in wp-content/upgrade after updating, once they have been reviewed and preserved if suspicious. `IT OPS` [S8] [S10]

Long term

- Keep the wp-content/upgrade/ block in the standard web server baseline. The fix randomizes the folder name but does not remove web access to it. `IT OPS` [S8]
- Retire or upgrade sites on WordPress 4.6 and earlier, and move others off older branches. WordPress actively supports only the most recent version. `LEADERSHIP` [S3] [S4]

- Where it suits the site, deploy through Composer or git with DISALLOW_FILE_MODS set to true, so the in-place upgrader never runs in production. `IT OPS` [S14]
- Set a minimum web log retention and forward logs centrally, including for hosted sites, so short-window attacks can be investigated after the fact. `LEADERSHIP` [S10]

Workarounds & compensating controls

- Where an update must wait, keep the path block in place and do not start a core update until it is verified. The risk arises only during an update, and the block must stay until the site is fixed. `IT OPS` [S6] [S8]
- Use a server, CDN or endpoint firewall layer, not a plugin that loads with WordPress. The staged copy loads its own files, so a PHP-level firewall may not see the request. `IT OPS` [S7] [S10]
- Treat hosting-provider protections, such as those announced by IONOS and Pantheon, as temporary. Both still tell customers to update. `LEADERSHIP` [S16] [S17]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: WordPress RCE Flaw Draws Nearly 63,000 Attack Attempts in Just 24 Hours
Published 2026-10-30 · `B3` Usually reliable, possibly true
Briefing source. Technical details match other sources; the 62,969 figure is not independently confirmed. Says no CVE exists, which predates the CVE record.

[S2] WordPress (GitHub Security Advisory): A race condition during core updates that could lead to remote code execution (GHSA-4w3m-c66w-69mg)
Published 2026-10-29 · `A1` Completely reliable, confirmed by other sources
Primary vendor advisory. Rates severity Low and lists no CVE or CVSS vector.

[S3] WordPress.org: WordPress 7.1.4
Published 2026-10-28 · `A1` Completely reliable, confirmed by other sources
Primary release announcement, last modified 2026-10-29.

[S4] WordPress.org Documentation: Version 7.1.4
Published 2026-10-28 · `A1` Completely reliable, confirmed by other sources
Primary release notes, including the backport list and revised files.

[S5] CVE Program (Wordfence CNA): CVE-2026-119977 record
Published 2026-10-31 · `A1` Completely reliable, confirmed by other sources
Primary CVE record with CVSS vector, CWE-367 and code references.

[S6] Wordfence (repost on Malware News): WordPress 7.1.4 Patches Unauthenticated Upgrade-Window RCE; Exploitation Attempts Detected After Release
Published 2026-10-29 · **A2** Completely reliable, probably true
Original researcher telemetry, read through a repost because the live Wordfence pages returned no content to the fetch tool. Later edits to the original would not be reflected. Original: https://www.wordfence.com/blog/2026/10/wordpress-7-1-4-security-release-rce/

[S7] Patchstack: WordPress 7.1.4 Security Release
Published 2026-10-28 · **B2** Usually reliable, probably true
Independent technical analysis of the root cause and fix. Patchstack sells a WordPress security product.

[S8] Ostorlab: WordPress Core Upgrade-Window RCE, Fixed in 7.1.4 (CVE-2026-119977)
Published 2026-10-31 · **B2** Usually reliable, probably true
Secondary technical analysis. Content current to 2026-10-31; exact post date not confirmed.

[S9] Rescana: WordPress Core 7.1.4 Fixes an Unauthenticated Upgrade-Window Race RCE (CVE-2026-119977)
Published 2026-10-31 · **C2** Fairly reliable, probably true
Secondary summary. Useful for the check of the 62,969 figure against Wordfence's post.

[S10] ThreatDefence: WordPress 7.1.4 Upgrade-Window RCE: Hunting CVE-2026-119977
Published 2026-10-31 · **C2** Fairly reliable, probably true
Most recent source found, updated 2026-11-02. Hunting logic is the author's analysis and not observed attacker activity.

[S11] CISA: Known Exploited Vulnerabilities catalog (version 2026.10.30)
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Read the newest entries of a newest-first file. No entry for this CVE seen; the catalog version predates the CVE record, so recheck.

[S12] FIRST: EPSS API result for CVE-2026-119977
Published 2026-11-02 · **A2** Completely reliable, probably true
Score 0.006, percentile 0.48701. A model estimate, not an observation.

[S13] Techaeris: WordPress RCE flaw nearly 63,000 attacks
Published 2026-10-30 · **C3** Fairly reliable, possibly true
Secondary. Relays Wordfence's Alex Thomas on blocking before updating. Frames the 62,969 window differently from The Hacker News.

[S14] HOL Guard: WordPress 7.1.4: a race in the core upgrade process let an unauthenticated visitor reach the unpacked installer mid-update
Published 2026-10-28 · `C3` Fairly reliable, possibly true
Snapshot from 2026-10-28 with tracking ended, so its statement that no exploitation was reported is out of date. Used for exposure conditions and early backport availability.

[S15] Web Hosting Today: WordPress 7.1.4 fixes 22 flaws, one in the core update process
Published 2026-10-29 · `C2` Fairly reliable, probably true
Secondary. Source of install-share figures and release chronology.

[S16] IONOS: WordPress 7.1.4 security update
Published · `B3` Usually reliable, possibly true
Host's own statement about its protections, not independently verified. Page undated.

[S17] Pantheon: WordPress 7.1.4 release note
Published 2026-10-28 · `B3` Usually reliable, possibly true
Host's own statement. Does not say which fixed flaws its mitigations cover.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-10-28	WordPress 7.1.4 is released, fixing 22 vulnerabilities including the upgrade race, with backports for older branches.	[S3] [S4]
2026-10-28	Backport packages for 6.5.14 and older returned 404 at 18:50 UTC, per one source, and the release post said backports would ship as ready.	[S3] [S14]
2026-10-28	Wordfence deploys its firewall rule at 20:30 UTC. The first match arrives nine minutes later.	[S6]
2026-10-29	WordPress publishes GHSA-4w3m-c66w-69mg, rated Low. Wordfence reports more than 18,500 requests in 21 hours.	[S2] [S6]
2026-10-30	The Hacker News reports 62,969 blocked attacks in 24 hours. CISA KEV catalog version 2026.10.30 is released without this flaw, and the CVE ID is reserved.	[S1] [S5] [S11]
2026-10-31	Wordfence publishes CVE-2026-119977 as CNA with CVSS 8.1 and CWE-367.	[S5]

Date	Event	Source
2026-11-02	EPSS stands at 0.6%. The latest reporting still shows no confirmed compromise, no public proof of concept and no KEV listing.	[S10] [S12]
2026-11-27	Scheduled date for the Wordfence rule to reach Free users after the 30-day delay.	[S6]

Relevance to Indianapolis, Indiana & managed clients

No source reports Indiana-specific targeting or victims, and this activity appears opportunistic. WordPress commonly runs public websites for local governments, school districts, clinics, manufacturers and small businesses across Indianapolis and Indiana, and these are often the sites with outsourced upkeep, shared hosting and short log retention. A compromise would most directly threaten website integrity, form data and credentials stored on the site, plus neighboring sites on a shared host. Healthcare and government organizations should check whether their sites collect patient, resident or student information, because that affects the response if compromise is found. Managed IT clients are the priority for fleet-wide action: push the upgrade-folder block and updates centrally, include agency-built and marketing-owned sites in the inventory, and do not rely on the Wordfence Free tier for this flaw before 2026-11-27. Client-facing reports should say that this is a limited-window flaw with heavy probing, so that the attack counts are not read as evidence of compromise.

Intelligence gaps

- No confirmed victim or successful compromise has been reported, which may reflect either the difficulty of winning the race or weak detection.
- Attacker identity, tooling, source IPs, user agents and post-exploitation payloads are unpublished.
- The origin and time window of the 62,969 figure are unresolved. Check Wordfence's own pages directly, since they could not be read for this report.
- It is unclear how many real-world updates create the exposure. Wordfence requires a full package with installer files, while Patchstack says the window recurs on every update, including unattended ones. No source measures how often automatic updates stage the installer.
- Sources differ on predictability: Patchstack says the folder name was predictable for admin uploads, while others describe it more generally. How often a path can be found without directory listing is unknown.
- No source reports the share of sites where wp-content/upgrade is web-reachable, or the patch rate since 2026-10-28.
- NVD had not analyzed the CVE as of the latest reporting, and the NVD page itself could not be read for this report. Watch for NVD scoring, a GHSA update adding the CVE, a KEV listing and a public proof of concept.
- Whether 4.6 and earlier are exploitable is not stated. They sit outside the affected range and receive no fixes.

Other notes

- Severity dispute: WordPress rates the advisory Low, Wordfence scores it CVSS 8.1 High with high attack complexity, and Patchstack calls it impractical to exploit. Wordfence and Patchstack both sell WordPress security products.
- Status wording: the briefing's 'actively exploited' label reflects exploitation attempts. Sources do not confirm a successful attack.

- Count dispute: 18,500+ in 21 hours appears in Wordfence's post as read through the repost. 62,969 appears in The Hacker News as 'past 24 hours' and in Techaeris as the first 24 hours after release. The numbers may reflect different counters or later data, but no source explains the difference.
- The fix: Patchstack and Ostorlab agree it adds a random suffix to the folder name (16 characters per Patchstack), keeps an index.php in the upgrade folder, and stops wp-config.php being copied from the working directory. Sources cite different commit hashes, b625b2d49c6a (Ostorlab) and e7b33f536d (HOL Guard), which were not checked against the repository.
- After patching, a randomly suffixed folder under wp-content/upgrade during an update is expected and is not an indicator by itself.
- Reporter: all sources that name a reporter credit Umut Bayram; only Ostorlab gives his affiliation, as Picus Security.
- Other fixes: 7.1.4 fixes 21 other issues, mostly stored XSS and Interactivity API flaws needing accounts, plus unauthenticated exposure of unpublished Customizer changes. A site immune to the race through DISALLOW_FILE_MODS or a path block still needs the update.
- Install share reported as of 2026-10-29: 64.4% on 7.1, 34.6% on 4.7 to 7.0, and 0.95% on versions older than 4.7 [S15].
- A separate WordPress Core flaw, CVE-2026-87902 (remote file inclusion), entered KEV on 2026-09-25 with a due date of 2026-09-28 [S11]. It should not be confused with this one. Recheck KEV for CVE-2026-119977, because the catalog version read predates the CVE record.

CTI-20261102-03 v1.0 · Generated 2026-11-02 12:40 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.